

A Data Collection Templates

This section contains the template used for every interviewee in this case study.

A.1 Pre-Interview Questionnaire

Background Interview Questions⁵

1. IQ: What is your role in the company?
2. IQ: How many years of experience did you collect over your professional career? (Current position and previous stations)
3. IQ: Did you have any experience, training, or education in Machine Learning Security/ Adversarial Machine Learning? (Yes, No)
 - a. IF Yes: Please elaborate on the experience, training, or education.

A.2 Interview Guide

Consent Agreement [Template]⁶

[Names of researchers and contact information]

- Procedures used in the empirical study, i.e., a short description of what the participant should do during the study and what steps the researcher will carry out during these activities.
- A text clearly stating that the participation is voluntary and that collected data will be anonymous.
- A description of how confidentiality will be assured. This includes describing how collected material will be coded and identified in the study.
- Purpose of empirical study.

Main Interview Questions (IQ) List⁷

4. IQ: Could you briefly explain your understanding of the terms ML and Security, ideally with an example, please?
5. IQ: Could you explain your understanding of ML Security, ideally with an example, please?
6. IQ: Which Security goals are announced by your company's management?⁸
 - a. How does your organization support ML Security?

Explanation: Software-intensive Products and Services (SIPS) are software systems fulfilling the requirements:

- large and complex
- subject to numerous engineering practices
- in a dynamic environment

Example for SIPS: Spotify App

Not a SIPS: Toy example implemented in the lab and used in an experiment

7. IQ: Why do you consider security aspects of ML components in your SIPS, for example, during your last project?⁹
8. IQ: What ML models are applied in your ML-intensive SIPS?

IF ML models are applied:

9. IQ: Which role does the security of your ML models play for the overall security of your SIPS?

ELSE (e.g., Third Party components containing ML functionalities are part of the SIPS): Continue with the next question...

Context: We distinguish between two scenarios in the next question:

- Scenario 1: Implemented ML Integration: SIPS that already incorporate an ML component
- Scenario 2: Planned ML Integration: SIPS, where an ML component will be implemented into

10. IQ: What is the difference in security aspects assessment of already-implemented ML-intensive SIPS and a planned ML integration into SIPS?¹⁰

⁵We reuse the *Background Topics* section of the template provided by Taylor et al. [47].

⁶We will use a similar structure as proposed by Runeson and Höst [38]

⁷The Interview Questions (IQs) are inspired by *The Doing Itself* and *Distanced Perspectives on the Doing* sections from the Interview Guide Template provided by Taylor et al. [47]. Furthermore, this study investigated the interview questions and questions of other studies conducted with practitioners by Grosse et al. [19], Mink et al. [28], and Kumar et al. [25].

⁸Alludes to organizational goals contradicting ML security goals as reported by [28]

⁹Alludes to Grosse et al. [19] questionnaire's "Part II - AI within your organization"

¹⁰Alludes to Grosse et al. [19] questionnaire's "Part II - AI within your organization"

11. IQ: How do you conduct Risk Assessment of ML-intensive SIPS in your last project?
 - a. How relevant was the familiarity with ML Security in the domain/system under consideration before conducting Risk Assessment of an ML-intensive SIPS in your last project?
 - i. Which roles were involved?
 - ii. How did those roles interact?
 - b. How did you document the Risk Assessment Results?
12. How do you generally conduct Risk Assessment?
 - a. Which System Modeling types are applied to conduct Risk Assessment of an ML-intensive SIPS?
 - b. Which perspective do you select (System-, Attacker- or Asset-Centric)?
 - c. Which methodologies do you choose (STRIDE¹¹, PASTA [51]¹², TARA¹³ or completely different ones)?
 - i. **IF no Methodology is used**
 - ii. IQ: Why are you not using any methodologies?
 - iii. **IF no Methodology is used**
 - iv. IQ: Which methodologies did you consider using?
 - d. During the Threat Modeling/Risk Assessment, did you apply any curated attack repositories, such as ATLAS MITRE^{14,15}?
 - e. How often do you see the need to conduct Threat Modeling/Risk Assessment of an ML-intensive SIPS and why (one-time or continuous Threat Modeling)?
 - f. Which challenges occur during Threat Modeling/Risk Assessment of ML-intensive SIPS?
 - i. How are these challenges different from non-ML-intensive SIPS?
13. IQ: How do you select the appropriate defense mechanism to protect ML-intensive SIPS based on your Threat Modeling/Risk Assessment?¹⁶
14. IQ: How do you apply the results of the Threat Modeling/Risk Assessment in the subsequent ML-intensive SIPS development stages?¹⁷
15. IQ: Which additional procedures had to be implemented after the initial security evaluation of the planned ML integration in your company before the planned ML integration was executed? (New procedures, protocols, or alteration of the current workflow, etc.)

Future Needs and Wishes

Instructions The following questions require a scale-based answer and an optional comment. The scale ranges from:

- 1 insufficiently covered in my company
- 10 very well covered in my company

16. The ability to select fit-for-purpose ML components to include in your SIPS is...
17. The ability to evaluate security concerns ML components to include in your SIPS is...
18. The ability to maintain the ML components in SIPS is...
19. Any other points that should have been asked or mentioned during this interview?

If there is time...

20. IQ: During the Development, did you apply any secure ML coding guidelines as provided by Microsoft¹⁸ or National Cyber Security Centre^{19,20}?

¹¹STRIDE = Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege, created by Microsoft <https://www.microsoft.com/en-us/security/blog/2012/08/16/threat-modeling-from-the-front-lines/>

¹²PASTA = Process for Attack Simulation and Threat Analysis

¹³TARA = Threat Assessment and Remediation Analysis, created by MITRE <https://www.mitre.org/news-insights/publication/threat-assessment-and-remediation-analysis-tara>

¹⁴<https://atlas.mitre.org>

¹⁵Alludes to Suggestions for secure ML Engineering in the development stage as reported by Kumar et al. [25]

¹⁶Alludes to practitioners' inability to identify and address threats as reported by Mink et al. [28]

¹⁷Alludes to practitioners' inability to identify and address threats as reported by Mink et al. [28]

¹⁸<https://learn.microsoft.com/en-us/azure/machine-learning/concept-secure-code-best-practice?view=azureml-api-2>

¹⁹<https://www.ncsc.gov.uk/files/Guidelines-for-secure-AI-system-development.pdf>

²⁰Alludes to Suggestions for secure ML Engineering in the development stage as reported by Kumar et al. [25]

21. IQ: Did you use any form of automation in the form of tools or repositories to, for example, generate graphs or conduct attacks on your ML-intensive SIPS?²¹
22. IQ: Did you use any form of automation in the form of tools or repositories to, for example, generate graphs or conduct attacks on your ML-intensive SIPS?²²
23. IQ: Do you use any build-in ML security assurance in your deployment pipeline?²³
24. IQ: Do you conduct any form of Red Teaming against your ML-intensive SIPS by yourself or an external party?²⁴
25. IQ: How did your perspective on ML as a technology change when you realized it introduces security issues to your system?²⁵
26. IQ: What would you recommend to other companies considering the integration of ML into their SIPS?²⁶

Other Papers containing valuable information that contributed to formulate the interview questions

- Paper Title: "Security is not my field, I'm a stats guy": A Qualitative Root Cause Analysis of Barriers to Adversarial Machine Learning Defenses in Industry [28]
 - study investigates the cause of the lack of implemented ML security practices among practitioners besides the unawareness of AML
 - The study concludes that three main issues hinder practitioners from implementing and applying ML security practices: 1) Lack of institutional motivation and educational resources for ML security defenses, 2) an inability to identify and address ML Security Threats, and 3) organizational structures and goals leading to an indirect discouraging ML security practices
- Paper Title: Adversarial Machine Learning - An Industrial Perspective [25]
 - Unpreparedness to detect and protect of industry from AML attacks on its ML systems, although practitioners claim that successful attacks targeting ML models would have catastrophic consequences
 - Study covers the perspective of an ML engineer and an incident responder
 - Suggestions for secure ML Engineering in the development stage
 - * Curated Attack repositories like MITRE ²⁷, containing attack types and attack tactics on ML-intensive SIPS
 - * Secure Coding Practices for ML development
 - * Automated Graph Creation tools based on code as proposed by Gharibi et al. [17]
 - * Automated Code checking ML security tools to statically and dynamically analyze ML-intensive SIPS, such as cleverhans [32], secml [35] or Adversarial Robustness Toolbox (ART) [30]
 - * Logging and Auditing ML systems to monitor and detect ongoing AML attacks on ML-intensive SIPS, using suitable tools
 - Suggestions for secure ML Engineering in the deployment stage
 - * Automated deployment tools with build-in security assurance mechanisms in submitted code
 - * ML developers perform Threat Modeling applying the theoretical foundation presented in [33] to address
 - * Red Teaming against the ML-intensive SIPS
 - * Transparency Centers: a secure facility where security experts conduct deep level of code analysis developers

More input for interview questions here:

- <https://www-sciencedirect-com.miman.bib.bth.se/science/article/pii/S0164121221000650#tbl5>

²¹Alludes to Suggestions for secure ML Engineering in the development stage as reported by Kumar et al. [25]

²²Alludes to Suggestions for secure ML Engineering in the development stage as reported by Kumar et al. [25]

²³Alludes to Suggestions for secure ML Engineering in the deployment stage as reported by Kumar et al. [25]

²⁴Alludes to Suggestions for secure ML Engineering in the deployment stage as reported by Kumar et al. [25]

²⁵Alludes to Taylor et al. [47] advice provided in the *Distanced Perspectives on the Doing* sections from the Interview Guide Template

²⁶Alludes to Taylor et al. [47] advice provided in the *Distanced Perspectives on the Doing* sections from the Interview Guide Template

²⁷<https://atlas.mitre.org>